

Care Access Navigator

Risk Management Rubric - Criterion 5: Risk Communication

Purpose

This criterion is turning the technical risk work into information that different stakeholders can understand and act on. It combines an executive risk report, audience-specific communication planning, a visual dashboard design, automated alerting concepts, drill-down views, and a Key Performance Indicator framework with documented review processes.

1. Create the Executive Risk Report

- What:** Preparing a concise management-level summary of the most important risks, financial exposure, current controls, residual risk, and recommended actions.
- How:** Using the risk register, Business Impact Analysis, mitigation plan, monitoring results, and starter financial estimates to present only the information decision-makers need.
- Why:** Executives and managers need a summarized risk picture rather than raw technical evidence. The report is supporting prioritization, funding, ownership, and risk-acceptance decisions.

The executive report for Care Access Navigator is focusing on identity, access governance, privileged access, vendor access, and monitoring because those areas directly support the project's goal of protecting simulated electronic Protected Health Information (ePHI).

Executive Finding	Current Exposure	Financial / Business View	Recommended Action
Privileged account misuse	Critical inherent; High starter residual	High operational and compliance consequence if administrative access is abused	Restrict admin roles, require MFA, review privileged access, monitor elevation events
Credential compromise	Critical inherent; High starter residual	Could interrupt access and expose simulated ePHI; scenario exposure is among the highest	Enforce MFA, strengthen authentication policy, monitor failed/suspicious logins
Excessive RBAC privileges	Critical inherent; High starter residual	Can create unauthorized access across connected applications	Validate least-privilege mappings and complete periodic access certification
Stale employee/vendor access	Critical/High inherent; Moderate/Low starter residual after control	Creates preventable unauthorized-access exposure	Verify JML deprovisioning, enforce vendor expiry and review
Logging / monitoring weakness	High	Reduces ability to detect, investigate, and evidence suspicious activity	Validate log coverage, detection use cases, alert triage, and evidence retention

2. Present Financial Impact and Actionable Recommendations

- What:** Showing the business impact of selected scenarios and turning the findings into clear actions for management.
- How:** Using the starter Business Impact Analysis values and earlier quantitative analysis, then connecting each material exposure to an owner and a recommended next action.
- Why:** Risk communication becomes useful only when the audience understands both the consequence and what decision or action is expected.

Scenario / Asset	Starter Financial Impact	Management Interpretation	Action
Electronic Health Record (EHR) Simulator disruption	\$30,000	Highest starter BIA impact among listed critical assets	Prioritize recovery readiness and access-control validation
Keycloak IAM disruption	\$25,000	Broad dependency because multiple applications rely on centralized authentication	Prioritize IAM recovery, MFA, role integrity, and logging

Scenario / Asset	Starter Financial Impact	Management Interpretation	Action
Patient Portal disruption	\$15,000	Customer/user-facing access impact with longer recovery tolerance than IAM/EHR	Maintain recovery procedure and monitoring
Authentication / access log loss or unavailability	\$12,000	Reduces detection and investigation capability	Protect log collection, retention, and monitoring pipeline

3. Develop the Stakeholder Communication Plan

What:	Defining who needs risk information, what each audience needs to know, how the message is being tailored, and how often communication is occurring.
How:	Grouping stakeholders by decision role and technical depth, then assigning a communication format, message focus, owner, and schedule.
Why:	The same risk should not be communicated in the same way to every audience. Managers need business impact and decisions, while IAM and security analysts need technical findings and remediation details.

Audience	Information Need / Tailored Message	Format	Schedule	Owner
Program Sponsor / leadership	Top risks, financial impact, residual risk, decisions needed	1-page executive summary + dashboard	Monthly / major change	GRC Analyst
Department Managers	Access risk affecting their teams, review findings, approvals, remediation	Access-review report + action list	Quarterly / review cycle	GRC + IAM
IAM Analyst	RBAC gaps, JML exceptions, MFA/privileged-access actions	Technical worklist / ticket	Weekly during implementation	IAM Lead
Security Analyst	Detection gaps, alert quality, suspicious access events, incident findings	SIEM view + investigation notes	Weekly / after test event	Security Analyst
HR / Workforce Administrator	Joiner/mover/leaver status and unresolved lifecycle exceptions	JML exception report	Weekly or event-driven	IAM + HR role

4. Design the Visual Risk Dashboard

What:	Designing a management dashboard that summarizes risk, control, access-review, incident, and remediation information in one view.
How:	Using Tableau as the planned reporting tool and structuring the dashboard around summary metrics, risk trends, status colors, filters, and drill-down links to supporting risk/control records.
Why:	A dashboard is making the risk program easier to monitor and is allowing management to move from a high-level posture view into the details when a metric is concerning.

Dashboard Area	Metric / Visual	Drill-Down
Risk posture	Open risks by Critical/High/Moderate/Low; inherent vs residual risk	Risk ID -> rationale -> owner -> treatment -> evidence
IAM governance	Active users, privileged accounts, stale/expired accounts, access-review exceptions	User/role -> access source -> review result -> remediation
Monitoring / incidents	Failed-login alerts, privilege-escalation alerts, excessive ePHI events, incident status	Alert -> source event -> analyst notes -> containment/evidence
Control health	Controls implemented, tested, failed, overdue	Control -> test result -> exception -> corrective action
Remediation	Open actions, overdue actions, days-to-close	Action -> owner -> target date -> status history

5. Define Automated Alerting and Escalation

- What:** Defining which risk or control conditions should trigger an alert instead of waiting for the next scheduled report.
- How:** Using Microsoft Sentinel or an equivalent lightweight Security Information and Event Management (SIEM) simulation for security-event alerts and using the project tracking system for overdue risk/control/remediation thresholds.
- Why:** Automated or threshold-based alerts are reducing the chance that a material change is missed between formal review meetings.

Trigger	Starter Threshold	Alert / Escalation
Repeated failed logins	Example: 5+ failures in a short test window	Security Analyst reviews authentication event and determines whether escalation is needed
Disabled or expired account activity	Any successful/attempted activity after disable/expiry	Immediate IAM/Security review
New privileged-role assignment	Any unscheduled or unapproved privileged assignment	IAM review + manager validation
Critical/High risk overdue remediation	Target date passed with risk still open	Escalate to GRC Analyst and responsible manager
Access-review exception not closed	Exception exceeds agreed remediation window	Escalate to IAM/GRC and department manager

6. Build the Key Performance Indicator (KPI) Framework

- What:** Defining leading and lagging indicators that show both whether preventive activities are occurring and whether negative outcomes are still happening.
- How:** Tracking a small set of measurable indicators from IAM, access reviews, monitoring, control testing, incidents, and remediation, and assigning each metric a target and review owner.
- Why:** Key Performance Indicators are helping the project show progress over time instead of relying on one-time screenshots or narrative statements.

KPI	Type	Starter Target	Why it matters
Privileged accounts protected by MFA	Leading	100%	Shows preventive authentication coverage before an incident occurs
Leaver accounts disabled within target time	Leading	100% of tested leavers	Measures lifecycle-control timeliness
Access-review completion rate	Leading	100% of planned review scope	Shows governance activity is occurring
High/Critical remediation actions overdue	Leading	0	Shows whether known risks are being treated on time
Unauthorized / excessive-access incidents	Lagging	0 confirmed events	Measures undesirable outcome after controls
Mean time to triage simulated security alerts	Lagging	Within project target, e.g. < 30 min for test	Shows response efficiency after a detection occurs
Repeat control failures	Lagging	0 repeat failures after remediation	Shows whether corrective action is effective

7. Establish the Tracking and Review Process

- What:** Defining how risk communication artifacts and metrics are being kept current after the initial report is created.
- How:** Using Monday.com for task/risk/remediation tracking, Excel or the project risk register for structured records, Tableau for management visualization, and scheduled review meetings to validate changes and assign actions.
- Why:** A communication system becomes unreliable if dashboards, reports, and risk records are not reviewed and updated consistently.

Review Activity	Frequency	Participants	Output
Risk register review	Monthly and after major test/control change	GRC Analyst, IAM/Security as needed	Updated scores, owners, treatment/status, evidence
Access review	Quarterly simulation / planned project cycle	Department Manager, IAM, GRC	Exceptions and remediation actions
Security monitoring review	Weekly during test/monitoring period	Security Analyst	Alert quality, incidents, tuning actions
Executive risk review	Monthly / final project review	Program Sponsor, managers, GRC	Risk posture, decisions, accepted residual risks
KPI/dashboard validation	Monthly	GRC + metric owners	Confirmed metric definitions, data freshness, trend commentary

8. Criterion 5 Result

For Criterion 5, Care Access Navigator is converting technical risk information into a structured executive risk report, tailored stakeholder communications, a Tableau-oriented risk dashboard design, event/threshold alerting, drill-down views, and a KPI tracking framework with documented review schedules.

Important note: Dashboard metrics, thresholds, communication schedules, and targets are starter project values. They should be updated as actual monitoring data, access-review results, and stakeholder feedback become available.